# Лабораторна робота №12
# Використання PDO для обміну даними з СКБД

**Крайняк Михайло Юрійович, 451 група**

## 1. Мета і середовище

**Мета:** вивчити принципи підключення та виконання запитів до СКБД з використанням драйвера PDO.

**Середовище:** XAMPP, **PHP 8.2.12** з розширеннями `PDO`, `pdo_mysql`; СКБД **MariaDB 10.11.19** (сумісна з MySQL; у встановленому XAMPP компонента MySQL не було, тому використано офіційний портативний архів MariaDB з mariadb.org, сервер слухав лише 127.0.0.1:3306, користувач `root` без пароля — як у XAMPP). Вебсервер — вбудований сервер PHP `php -S 127.0.0.1:8000 -t src`; код працює й під Apache з XAMPP.

**Варіант 10:** розклад маршрутів автовокзалу. Сторінку `book.php` з прикладу «Каталог бібліотеки» реалізовано як `route.php` (сторінка одного рейсу).

**Кроки 1–2.** Роботу виконано в окремій папці; вміст `C:\xampp\htdocs` не очищувався, щоб не видалити інші проєкти, — для вбудованого сервера він не потрібен.

## 2. Структура бази даних (крок 3)

База `lab12_bus` (utf8mb4). Таблиця `users` має поля, вимагані завданням: ідентифікатор, логін, ПІБ, email, пароль (як хеш), а також дату реєстрації; логін і email унікальні. Таблиця `routes` містить рейси варіанта 10 (6 вигаданих записів). Базу створює `sql/setup.php` через PDO або імпорт `sql/schema.sql` у phpMyAdmin.

```
CREATE TABLE users (
    id            INT UNSIGNED NOT NULL AUTO_INCREMENT,
    login         VARCHAR(30)  NOT NULL,
    full_name     VARCHAR(100) NOT NULL,
    email         VARCHAR(100) NOT NULL,
    password_hash VARCHAR(255) NOT NULL,
    created_at    DATETIME     NOT NULL DEFAULT CURRENT_TIMESTAMP,
    PRIMARY KEY (id),
    UNIQUE KEY uq_users_login (login),
    UNIQUE KEY uq_users_email (email)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;

CREATE TABLE routes (
    id           INT UNSIGNED      NOT NULL AUTO_INCREMENT,
    number       VARCHAR(10)       NOT NULL COMMENT 'Номер рейсу',
    destination  VARCHAR(100)      NOT NULL COMMENT 'Пункт призначення',
    departure    TIME              NOT NULL COMMENT 'Час відправлення',
    duration_min SMALLINT UNSIGNED NOT NULL COMMENT 'Тривалість поїздки, хв',
    platform     TINYINT UNSIGNED  NOT NULL COMMENT 'Платформа 1–20',
    price        INT UNSIGNED      NOT NULL COMMENT 'Ціна квитка, грн',
```

```
    carrier      VARCHAR(100)      NOT NULL COMMENT 'Перевізник',
    days         VARCHAR(50)       NOT NULL COMMENT 'Дні курсування',
    PRIMARY KEY (id),
    KEY idx_routes_departure (departure),
    CONSTRAINT chk_routes_platform CHECK (platform BETWEEN 1 AND 20),
    CONSTRAINT chk_routes_price CHECK (price BETWEEN 1 AND 5000)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

## 3. Опис файлів

| **Файл** | **Призначення** |
|---|---|
| `src/config.php` | Параметри підключення (типово XAMPP); заміна через змінні середовища або `config.local.php` |
| `src/common.php` | Підключення PDO (`db()`), обробка помилок, сесія, CSRF, поточний користувач, спільне меню й шаблон, поле форми |
| `src/index.php` | Список рейсів, пошук за пунктом призначення (підготовлений запит з `LIKE`) |
| `src/route.php` | Сторінка одного рейсу за `id` |
| `src/register.php` | Форма реєстрації й обробка: перевірка полів, унікальність, `password_hash()`, `INSERT` |
| `src/login.php` | Форма входу, `password_verify()`, збереження користувача в сесії |
| `src/logout.php` | Вихід (POST із CSRF), знищення сесії |
| `src/users.php` | Список користувачів лише для авторизованих |
| `src/db_check.php` | Перевірка підключення PDO і структури таблиці `users` |
| `sql/schema.sql`, `sql/setup.php` | Створення бази й таблиць, початкові рейси |
| `tools/checks.sh` | Автоматичні перевірки (curl) і їх вивід `checks-output.txt` |

Готові приклади `users1-3.php` використано як відправну точку; їх код у роботу не перенесено, бо він виводить дані без екранування, показує текст помилки PDO користувачу й не перевіряє типи. Увесь код у `src` — власний.

## 4. Хід роботи зі знімками екрана

### Крок 4. Підключення PDO та обробка помилок

З’єднання створює функція `db()`: DSN `mysql:host=…;port=…;dbname=…;charset=utf8mb4`, режим помилок `ERRMODE_EXCEPTION`, вибірка асоціативними масивами, вимкнена емуляція підготовлених запитів. Виняток `PDOException` перехоплює кожна сторінка: текст помилки (з адресою сервера) іде в журнал, користувач бачить загальне повідомлення і код 500.

```
/** Єдине з’єднання PDO на запит. Помилки — винятками PDOException. */
function db(): PDO
{
    static $pdo = null;
    if ($pdo === null) {
```

```
        $config = require __DIR__ . '/config.php';
        $dsn = sprintf('mysql:host=%s;port=%d;dbname=%s;charset=utf8mb4',
            $config['host'], $config['port'], $config['name']);
        $pdo = new PDO($dsn, $config['user'], $config['pass'], [
            PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
            PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
            PDO::ATTR_EMULATE_PREPARES => false, // Справжні підготовлені запити на сервері.
        ]);
    }
    return $pdo;
}

/** Деталі помилки — лише в журнал сервера; користувачу — загальне повідомлення. */
function dbError(PDOException $exception): string
{
    error_log('PDO: ' . $exception->getMessage());
    http_response_code(500);
    return 'Помилка роботи з базою даних. Перевірте, що сервер MySQL запущено, і спробуйте пізніше.';
}
```

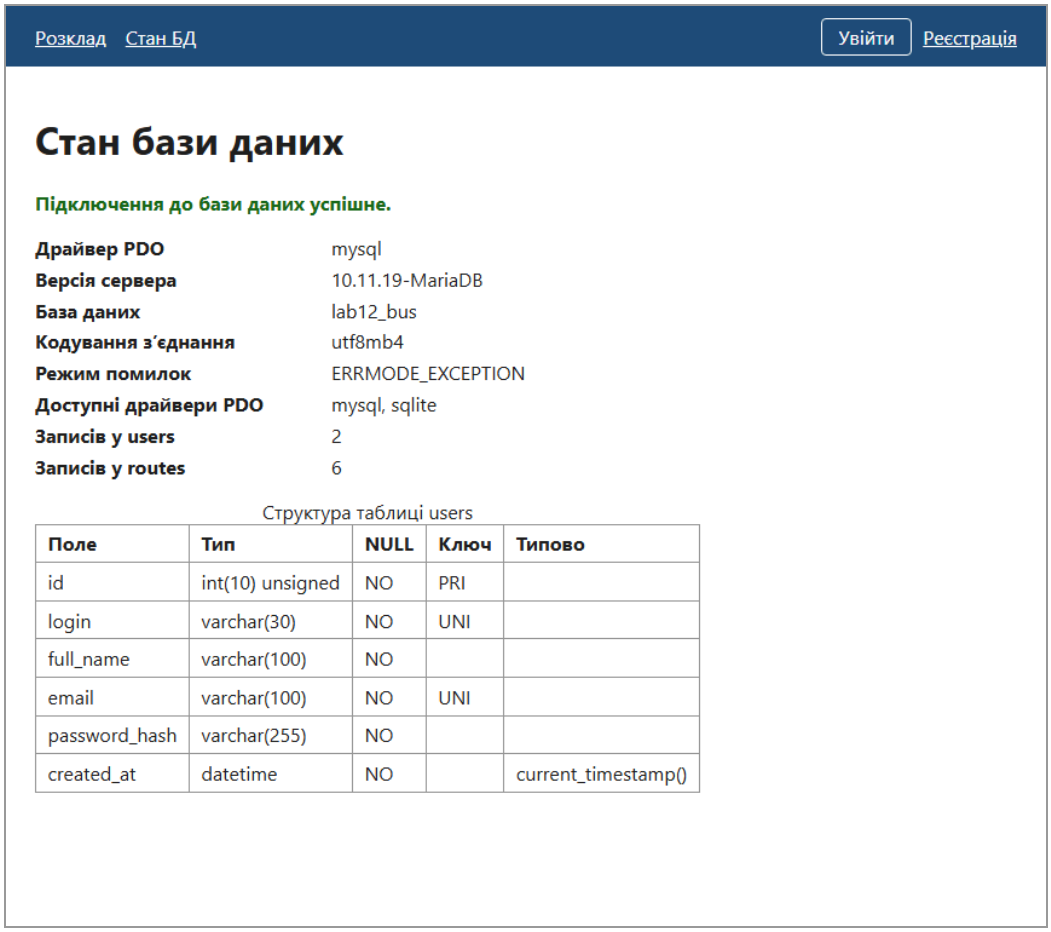



Рис. 1. `db_check.php`: успішне підключення, драйвер `mysql`, версія сервера, кодування `utf8mb4`, режим `ERRMODE_EXCEPTION`, кількість записів і структура таблиці `users` (`SHOW COLUMNS`).

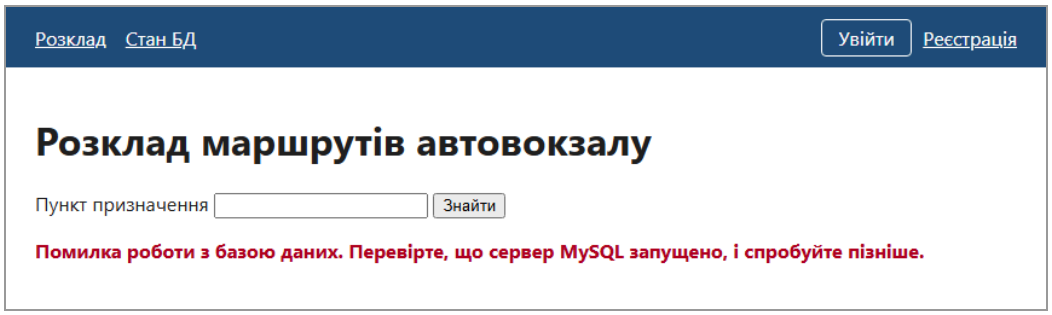



Рис. 2. Той самий застосунок, налаштований на порт, де немає сервера MySQL (`LAB12_DB_PORT=3999`): виняток перехоплено, показано загальне повідомлення без технічних деталей, код відповіді 500.

## Крок 6. Перегляд рейсів (index.php, route.php)

```
        $sql = 'SELECT id, number, destination, departure, platform, price FROM routes';
        $params = [];
        if ($query !== '') {
            // Значення передається параметром, а символи % і _ екрануються для LIKE.
            $sql .= ' WHERE destination LIKE :pattern';
            $params['pattern'] = '%' . addcslashes($query, '%_\\') . '%';
        }
        $stmt = db()->prepare($sql . ' ORDER BY departure, number');
        $stmt->execute($params);
        $routes = $stmt->fetchAll();
```

```
$id = filter_var($_GET['id'] ?? null, FILTER_VALIDATE_INT, ['options' => ['min_range' => 1]]);
if ($id === false || $id === null) {
    http_response_code(400);
    $error = 'Некоректний ідентифікатор рейсу.';
} else {
    try {
        $stmt = db()->prepare('SELECT * FROM routes WHERE id = :id');
        $stmt->bindValue(':id', $id, PDO::PARAM_INT);
        $stmt->execute();
        $route = $stmt->fetch() ?: null;
```

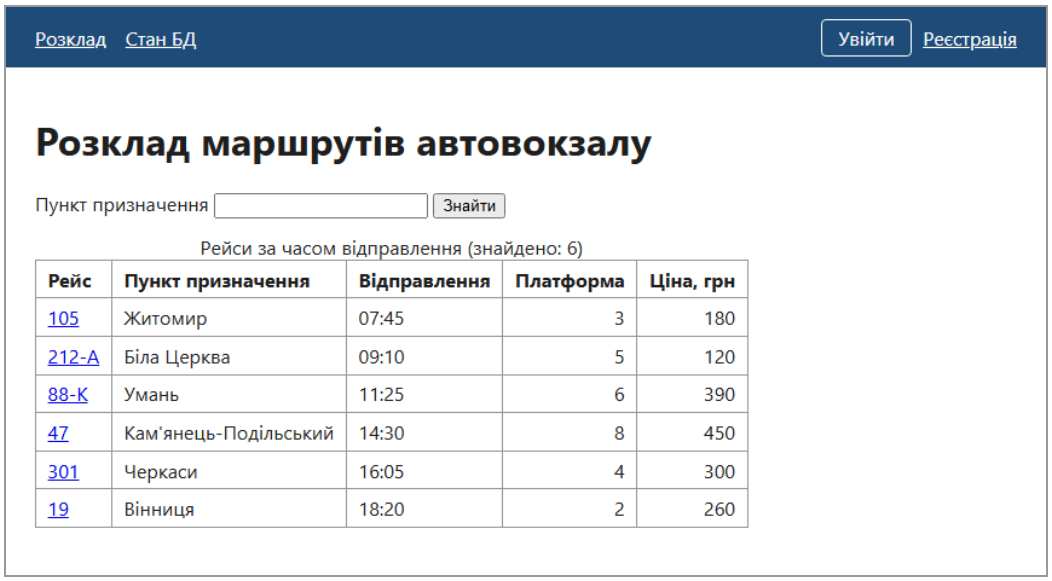



Рис. 3. `index.php` для гостя: рейси з таблиці `routes`, відсортовані за часом; номер рейсу — посилання на `route.php?id=…`. У меню — «Увійти» і «Реєстрація».

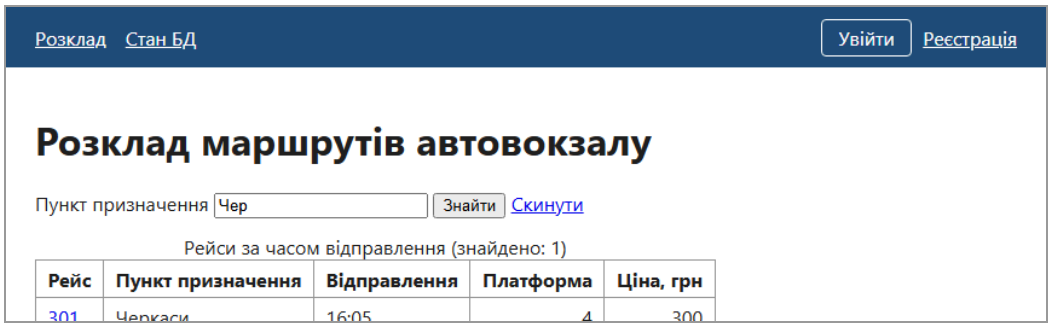



Рис. 4. Пошук «Чер»: значення передано параметром `:pattern`, символи `%` і `_` у запиті екрановано.

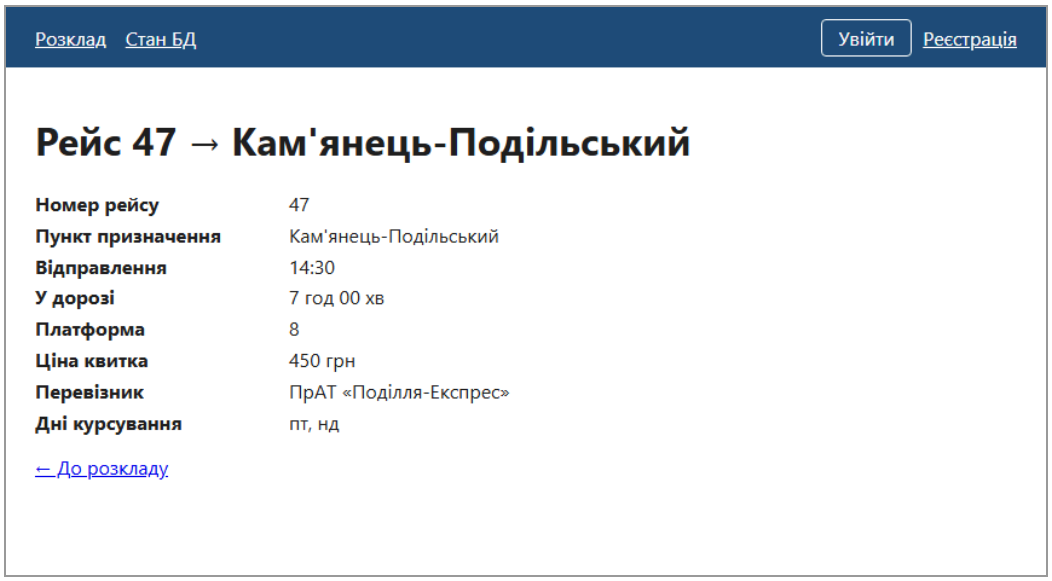



Рис. 5. `route.php?id=4`: один рейс, отриманий підготовленим запитом із `bindValue(':id', $id, PDO::PARAM_INT)`.




Рис. 6. Неіснуючий `id=999` — «Рейс не знайдено» (404); нечисловий `id` — 400.

### Крок 7. Реєстрація (register.php)

Поля перевіряються на сервері: логін — 3–30 латинських літер, цифр, «_»; ПІБ — щонайменше два слова з літер (апостроф і дефіс дозволені); email — `FILTER_VALIDATE_EMAIL`; пароль — від 8 символів і збіг із повтором. Унікальність логіна й email перевіряє підготовлений `SELECT`, а на випадок одночасної реєстрації — унікальні індекси (SQLSTATE 23000). Пароль зберігається лише як хеш `password_hash(…, PASSWORD_DEFAULT)` (bcrypt, 60 символів).

```
        if ($errors === []) {
            $stmt = db()->prepare('INSERT INTO users (login, full_name, email, password_hash)
                                   VALUES (:login, :full_name, :email, :password_hash)');
            $stmt->execute([
                'login' => $values['login'],
                'full_name' => $values['full_name'],
                'email' => $values['email'],
                'password_hash' => password_hash($password, PASSWORD_DEFAULT),
            ]);
            flash('Реєстрацію завершено. Увійдіть зі своїм логіном і паролем.');
            redirect('login.php');
```

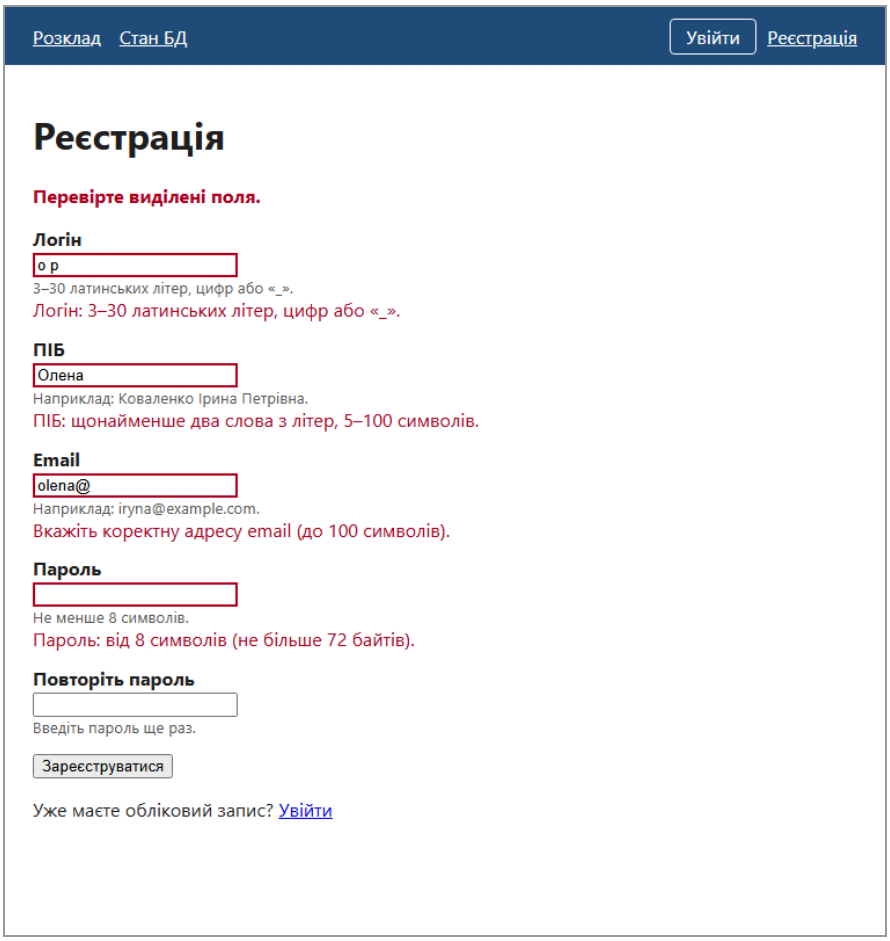



Рис. 7. Реєстрація з неправильними даними: повідомлення біля кожного поля, введені значення (крім пароля) збережено.

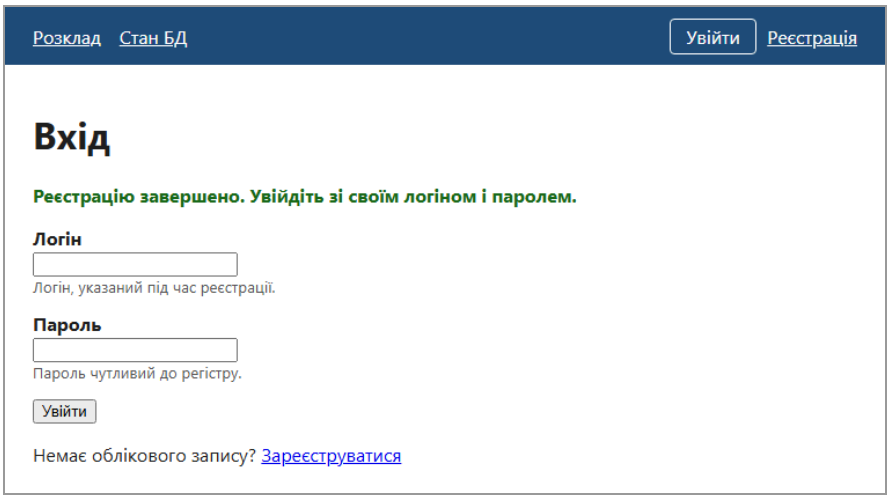



Рис. 8. Після успішної реєстрації — перенаправлення 303 на сторінку входу з повідомленням.

Вміст таблиці `users` після реєстрації (з виводу `tools/checks.sh`): у полі `password_hash` — рядок `$2y$10$…` довжиною 60, паролів у відкритому вигляді немає.

```
   1 | iryna_k | Коваленко Ірина Петрівна | iryna@example.com | $2y$10$ | 60
   2 | taras_m | Дем'яненко Тарас Олегович | taras@example.com | $2y$10$ | 60
   пароль у відкритому вигляді в БД: 0
```

## Крок 8. Авторизація (login.php) і сесія

```
            $stmt = db()->prepare('SELECT id, password_hash FROM users WHERE login = :login');
            $stmt->execute(['login' => $login]);
            $user = $stmt->fetch();
            // Однакове повідомлення для невідомого логіна й неправильного пароля.
            if ($user === false || !password_verify($password, $user['password_hash'])) {
                http_response_code(401);
                $formError = 'Невірний логін або пароль.';
            } else {
                if (password_needs_rehash($user['password_hash'], PASSWORD_DEFAULT)) {
                    $update = db()->prepare('UPDATE users SET password_hash = :hash WHERE id = :id');
                    $update->execute(['hash' => password_hash($password, PASSWORD_DEFAULT), 'id' =>
$user['id']]);
                }
                session_regenerate_id(true); // Новий ідентифікатор сесії після входу.
                $_SESSION['user_id'] = (int) $user['id'];
                $_SESSION['csrf'] = bin2hex(random_bytes(32));
                flash('Ви увійшли до системи.');
                redirect('index.php');
```

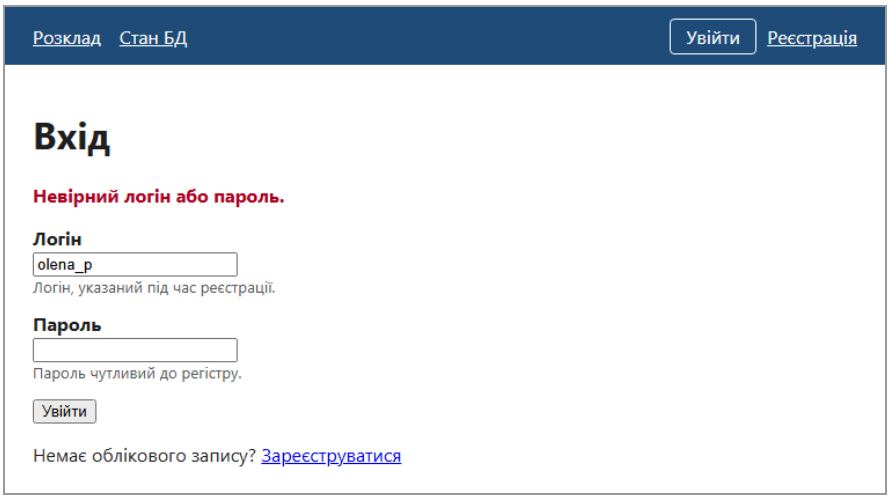



Рис. 9. Неправильний пароль: «Невірний логін або пароль» (401). Те саме повідомлення для невідомого логіна, щоб не розкривати, які логіни існують.

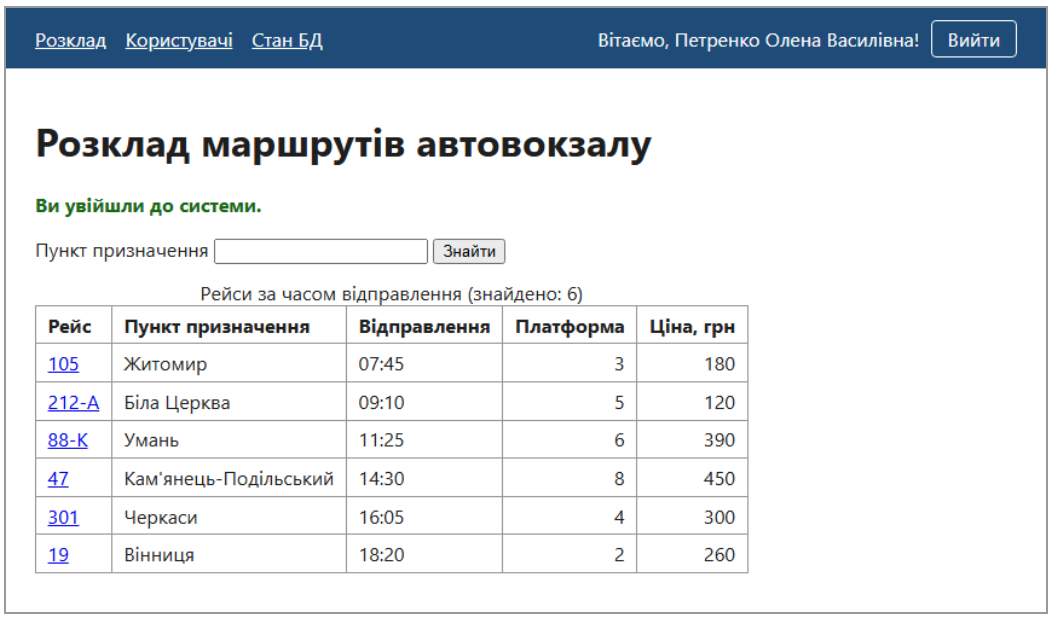



Рис. 10. Після входу: у верхньому меню — привітання з ПІБ користувача, кнопка «Вийти» і пункт «Користувачі». Ідентифікатор сесії після входу змінено (`session_regenerate_id(true)`).

### Крок 9. Вихід (logout.php)

Кнопка «Вийти» — форма POST із CSRF-токеном, тому стороннє посилання не може вивести користувача. Сесія очищується, cookie видаляється, `session_destroy()`.

```
$_SESSION = [];
$params = session_get_cookie_params();
setcookie(session_name(), '', [
    'expires' => time() - 3600,
    'path' => $params['path'],
    'domain' => $params['domain'],
    'secure' => $params['secure'],
    'httponly' => $params['httponly'],
    'samesite' => $params['samesite'] ?: 'Lax',
]);
session_destroy();
```

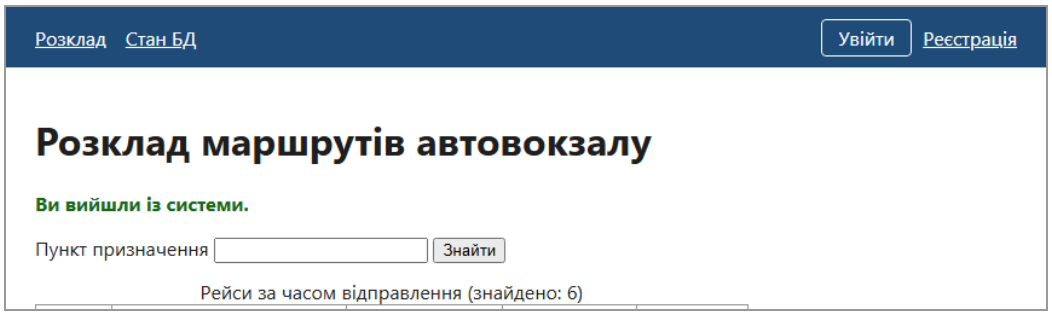



Рис. 11. Після виходу: повідомлення «Ви вийшли із системи», у меню знову «Увійти».

### Крок 10. Спільне верхнє меню

Меню формує функція `pageStart()` у `common.php` для всіх сторінок; стан визначає `currentUser()`, що читає користувача з БД за `$_SESSION['user_id']` (рис. 3 — гість, рис. 10 — авторизований користувач).

```
/** Поточний користувач із БД або null для гостя. */
function currentUser(): ?array
{
    static $user = false;
    if ($user !== false) {
        return $user;
    }
    $user = null;
    $id = $_SESSION['user_id'] ?? null;
    if (is_int($id)) {
        $stmt = db()->prepare('SELECT id, login, full_name, email FROM users WHERE id = :id');
        $stmt->execute(['id' => $id]);
        $user = $stmt->fetch() ?: null;
        if ($user === null) {
            unset($_SESSION['user_id']); // Користувача видалено з БД.
        }
    }
    return $user;
}
```

### Крок 11. Список користувачів (users.php)

```
/** Сторінки лише для авторизованих: гостя перенаправляємо на вхід. */
function requireLogin(): array
{
    $user = currentUser();
    if ($user === null) {
        flash('Увійдіть, щоб переглянути цю сторінку.');
        redirect('login.php');
    }
    return $user;
}
```

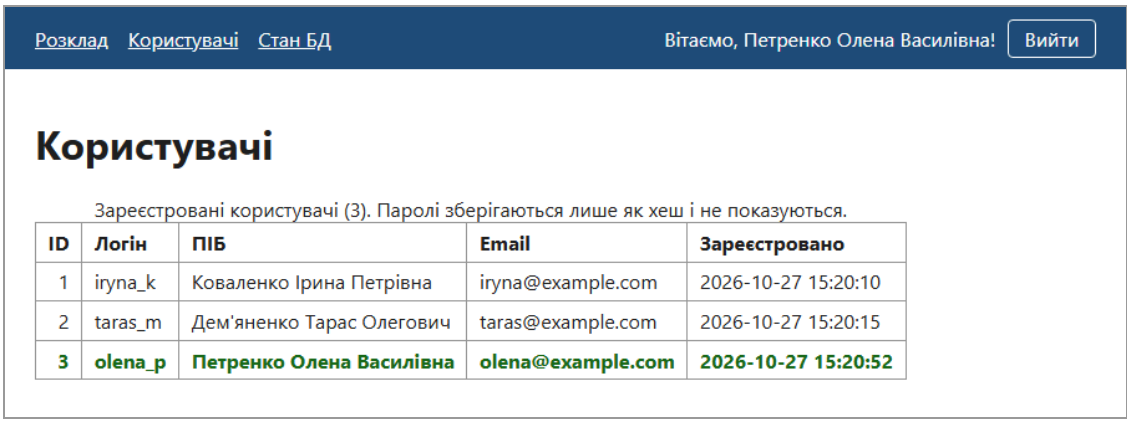



Рис. 12. `users.php` для авторизованого користувача: ID, логін, ПІБ, email, дата реєстрації; поточного користувача виділено. Хеші паролів не вибираються й не показуються.

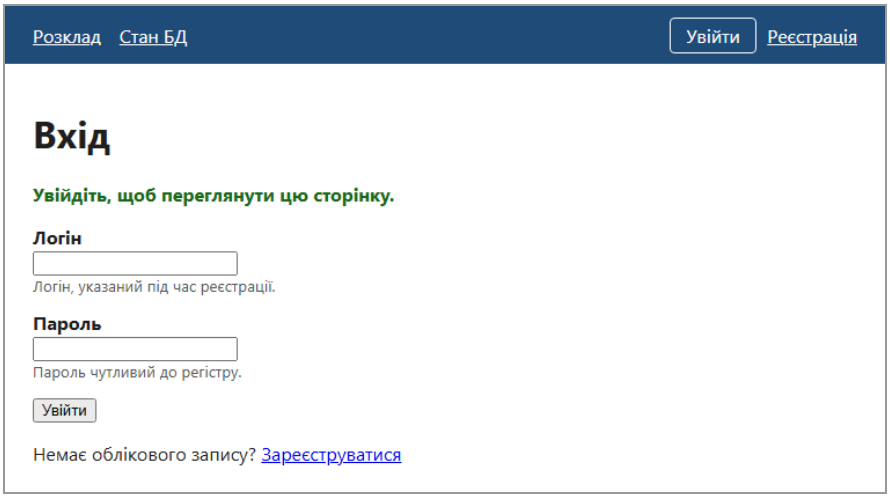



Рис. 13. Спроба гостя відкрити `users.php`: перенаправлення 303 на вхід із поясненням.

### Крок 12. Захист від SQL-ін’єкцій

Усі запити, що містять дані користувача, виконано через `prepare()` + `execute()` з іменованими параметрами; емуляцію вимкнено (`ATTR_EMULATE_PREPARES = false`), тож значення передаються серверу окремо від тексту SQL. Без параметрів виконуються лише сталі запити (`SELECT … FROM users ORDER BY id`). Ідентифікатори додатково перевіряються `FILTER_VALIDATE_INT`, а все виведення екранується `htmlspecialchars()`.

### Крок 13. Валідація HTML

Згенерований HTML 16 станів сторінок (гість і користувач, форми порожні й з помилками, 404, недоступна БД, помилка CSRF при виході тощо) перевірено W3C Nu Validator: **0 помилок і попереджень** для кожної сторінки.

## 5. Результати перевірок

| Перевірка | Очікувано | Фактично | |
|---|---|---|---|
| Список рейсів, пошук «Чер» | 6 рейсів; 1 збіг | 200, 6 рейсів; 1 рейс «Черкаси» | ✓ |
| Пошук `' OR 1=1 --` та `%` | Шукаються як текст | 200, 0 рейсів (без помилки SQL) | ✓ |
| `route.php?id=1` / 999 / abc / `1 OR 1=1` / `id[]=1` | Рейс / 404 / 400 | 200 «Житомир» / 404 / 400 / 400 / 400 | ✓ |
| Реєстрація коректна | Запис у БД, перехід на вхід | 303 → login.php; у БД хеш `$2y$10$…` (60 символів) | ✓ |
| Повторні логін / email | Відмова | 409 «Такий логін уже зайнятий» / «Цей email уже зареєстровано» | ✓ |
| Логін із лапкою, короткий пароль, різні паролі, неправильний email, ПІБ із `<script>`, масив `login[]` | Помилки полів | 422 з повідомленням біля відповідного поля; PHP-попереджень немає | ✓ |
| Реєстрація/вхід без CSRF-токена | Відмова | 403 «Форма застаріла…», запис не створено | ✓ |
| ПІБ з апострофом «Дем'яненко Тарас Олегович» | Збережено без спотворення | 303; у БД і на сторінці — без змін | ✓ |
| Вхід: невірний пароль / невідомий логін / `' OR '1'='1' --` | Відмова | 401 «Невірний логін або пароль» в усіх трьох випадках | ✓ |
| Вхід коректний | Сесія, привітання в меню | 303 → index.php; «Вітаємо, Коваленко Ірина Петрівна!», «Вийти»; ідентифікатор сесії змінено | ✓ |
| `users.php` гостем / після входу | Перехід на вхід / список | 303 → login.php / 200, 2 користувачі, хешів на сторінці немає | ✓ |
| Вихід через GET / POST без CSRF | Сесія зберігається | 303 на головну / 403; `users.php` доступний (200) | ✓ |
| Вихід POST із CSRF | Сесію завершено | 303 → index.php, у меню «Увійти»; `users.php` → 303 на вхід | ✓ |
| Сервер MySQL недоступний | Контрольована помилка | 500 із загальним повідомленням на index, route, db_check і при вході; без SQLSTATE і стеку | ✓ |
| W3C Markup Validation | Без помилок | 0 помилок і попереджень для 16 станів сторінок | ✓ |

## 6. Відповіді на контрольні питання

1. **PDO** (PHP Data Objects) — розширення PHP з єдиним об’єктним інтерфейсом доступу до реляційних СКБД. Використовується для підключення до БД, виконання

запитів (зокрема підготовлених), отримання результатів і керування транзакціями незалежно від конкретної СКБД.

2. Переваги: один API для різних СКБД (змінюється лише DSN), зручні параметризовані запити з іменованими параметрами, обробка помилок винятками, підтримка транзакцій (`beginTransaction`/`commit`/`rollBack`), гнучкі режими вибірки (масиви, об'єкти, класи). На відміну від `mysqli`, PDO не прив'язаний до MySQL.
3. PDO підтримує драйвери MySQL/MariaDB (`pdo_mysql`), PostgreSQL (`pdo_pgsql`), SQLite (`pdo_sqlite`), Microsoft SQL Server (`pdo_sqlsrv`), Oracle (`pdo_oci`), Firebird, IBM DB2, ODBC та інші. Доступні драйвери показує `PDO::getAvailableDrivers()` (у роботі — mysql, sqlite).
4. Створити об'єкт `new PDO($dsn, $user, $password, $options)`, де DSN, наприклад, `mysql:host=127.0.0.1;port=3306;dbname=lab12_bus;charset=utf8mb4`; в опціях задати `PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION`, режим вибірки та за потреби вимкнути емуляцію підготовлених запитів.
5. Режим помилок задає `PDO::ATTR_ERRMODE`: `ERRMODE_SILENT` (лише коди через `errorCode()`/`errorInfo()`), `ERRMODE_WARNING` (попередження PHP), `ERRMODE_EXCEPTION` (кидається `PDOException`; типово з PHP 8). Помилка конструктора завжди дає виняток. Виняток перехоплюють `try/catch`, деталі (`getMessage()`, SQLSTATE у `getCode()`) пишуть у журнал, користувачу показують загальне повідомлення.
6. Параметризований запит містить замість значень позначки — іменовані (`:login`) або позиційні (`?`). Запит готують `$stmt = $pdo->prepare($sql)`, значення передають у `$stmt->execute(['login' => $login])` або через `bindValue()`/`bindParam()` із типом (`PDO::PARAM_INT`). Значення ніколи не вставляються в текст SQL.
7. Безпека: дані передаються окремо від тексту SQL, тому лапки чи `OR 1=1` у даних не змінюють структуру запиту (SQL-ін'єкція неможлива). Продуктивність: підготовлений запит розбирається сервером один раз і може виконуватися багато разів із різними параметрами (`execute()` у циклі). Назви таблиць і стовпців параметрами не передаються — їх беруть лише зі списку в коді.
8. `fetch(PDO::FETCH_ASSOC)` / `fetchAll(PDO::FETCH_ASSOC)` — асоціативні масиви; `PDO::FETCH_OBJ` — об'єкти `stdClass` (`$row->login`); `PDO::FETCH_CLASS` — об'єкти заданого класу; `fetchColumn()` — одне значення. Типовий режим задається опцією `PDO::ATTR_DEFAULT_FETCH_MODE` (у роботі — `FETCH_ASSOC`).

## 7. Висновок

У роботі за допомогою PDO реалізовано застосунок «Розклад маршрутів автовокзалу» (варіант 10) з базою MySQL/MariaDB: перегляд і пошук рейсів, сторінку рейсу, реєстрацію з хешуванням паролів, вхід і вихід із сесією, спільне меню та список користувачів лише для авторизованих. Усі запити з даними користувача — підготовлені, помилки СКБД

обробляються винятками без розкриття деталей, форми захищені CSRF-токеном. Усі перевірки, зокрема спроби SQL-ін’єкцій, пройдено, HTML усіх сторінок валідний.

## 8. Посилання на репозиторій

Репозиторій: https://github.com/mykhailokrainiak/web-progr
Папка з лабораторною роботою: https://github.com/mykhailokrainiak/web-progr/tree/main/lab12

## Додаток А. Вивід tools/checks.sh

```
== Підготовка БД
База lab12_bus готова: таблиці users і routes, рейсів: 6.

== Перегляд рейсів (index.php, route.php)
index: 200 / рейсів 6
пошук «Чер»: 200 / рейсів 1: Черкаси
пошук SQL-ін'єкції «' OR 1=1 -- »: 200 / рейсів 0
пошук «%» (екранування LIKE): 200 / рейсів 0
q[]=x: 400 Некоректний пошуковий запит.
route.php?id=1: 200 Житомир
route.php?id=999: 404 Рейс не знайдено.
route.php?id=abc: 400 Некоректний ідентифікатор рейсу.
route.php?id=1 OR 1=1: 400 Некоректний ідентифікатор рейсу.
route.php?id[]=1: 400 Некоректний ідентифікатор рейсу.

== Меню гостя і доступ до users.php
меню: Увійти,Реєстрація
users.php гостем: 303 → login.php

== Реєстрація
коректна: 303 → login.php
той самий логін: 409 login: Такий логін уже зайнятий.
той самий email: 409 email: Цей email уже зареєстровано.
логін із лапкою: 422 login: Логін: 3–30 латинських літер, цифр або «_».
короткий пароль: 422 password: Пароль: від 8 символів (не більше 72 байтів).
паролі різні: 422 password_confirm: Паролі не збігаються.
email некоректний: 422 email: Вкажіть коректну адресу email (до 100 символів).
ПІБ із тегом: 422 full_name: ПІБ: щонайменше два слова з літер, 5–100 символів.
login[] масивом: 422 login: Логін: 3–30 латинських літер, цифр або «_».
без CSRF: 403 Форма застаріла. Оновіть сторінку й спробуйте ще раз.
ПІБ з апострофом: 303 → login.php
користувачі в БД:
   1 | iryna_k | Коваленко Ірина Петрівна | iryna@example.com | $2y$10$ | 60
   2 | taras_m | Дем'яненко Тарас Олегович | taras@example.com | $2y$10$ | 60
   пароль у відкритому вигляді в БД: 0

== Вхід
невірний пароль: 401 Невірний логін або пароль.
невідомий логін: 401 Невірний логін або пароль.
SQL-ін'єкція в логіні: 401 Невірний логін або пароль.
без CSRF: 403 Форма застаріла. Оновіть сторінку й спробуйте ще раз.
коректний: 303 → index.php
ідентифікатор сесії змінено: так
меню: Користувачі,Вітаємо, Коваленко Ірина Петрівна!,>Вийти< | Ви увійшли до системи.
users.php: 200 / рядків 2; хеш на сторінці: 0

== Вихід
GET logout.php: 303 → index.php; users.php після цього: 200
POST без CSRF: 403 Форма застаріла. Оновіть сторінку й натисніть «Вийти» ще раз.; users.php: 200
POST з CSRF: 303 → index.php
```

```
меню: Увійти | Ви вийшли із системи.
users.php після виходу: 303 → login.php

== Недоступна БД (сервер :8001, порт MySQL 3999)
index: 500 Помилка роботи з базою даних. Перевірте, що сервер MySQL запущено, і спробуйте пізніше.
route.php?id=1: 500 Помилка роботи з базою даних. Перевірте, що сервер MySQL запущено, і спробуйте
пізніше.
db_check.php: 500 Помилка роботи з базою даних. Перевірте, що сервер MySQL запущено, і спробуйте пізніше.
вхід: 500 Помилка роботи з базою даних. Перевірте, що сервер MySQL запущено, і спробуйте пізніше.
```